



Security Audit & Assessment MECR2123

AUDIT LAB 2

(Due date: 1 July 2026)

Session 2025/2026-2

Lecturer: Assoc. Prof. Ts. Dr. Siti Hajar Othman

NAME	Keertennah Devi A/P Ponnambalam
MATRICES NO	MEC254026

INDIVIDUAL TASK

Cybersecurity Assessment Using CISA's Cyber Security Evaluation Tool (CSET)

Ransomware Readiness Assessment (RRA) and Cyber Infrastructure Survey (CIS)

Prepared by: Keertennah Devi A/P Ponnambalam

Assessment Scope: National Oilwell Varco

Platform: CISA Cyber Security Evaluation Tool (CSET)

Assessment Dates: 1 July 2026

1.0 Platform Access

The Cyber Security Evaluation Tool (CSET) is a free and stand-alone desktop application released by the U.S. Cybersecurity and Infrastructure Security Agency (CISA). It guides asset owners and operators through a systematic, question-based process for evaluating the cybersecurity practices of both Information Technology (IT) and Operational Technology (OT) environments. CSET packages a number of assessment modules that can be run independently or combined within a single project, including the NIST Cybersecurity Framework (NIST CSF), Cybersecurity Performance Goals (CPG), the Minimum Viable Resilience Assessment (MVRA), the Cyber Infrastructure Survey (CIS), and the Ransomware Readiness Assessment (RRA) used for this task.

Each module follows a similar workflow inside CSET, creates a new assessment, selects the maturity module, answers the module's question set, optionally record supporting observations and evidence, and generates the built-in analysis reports.

2. 0 Assessment Selection and Justification

Two complementary CSET modules were selected and completed for National Oilwell Varco:

- Ransomware Readiness Assessment (RRA)
- Cyber Infrastructure Survey (CIS)

Justification: The RRA answers a narrow but high-consequence audit question using a threat-focused, progressively tiered practice set. The CIS complements this with a wide-angle view of the organisation's overall cybersecurity management, architecture, workforce, controls, and dependencies, which is where root cause weaknesses that could still enable or worsen a ransomware event are more likely to surface even when the ransomware-specific checklist is fully satisfied. Running the narrow, threat-specific survey alongside the broad, capability-based survey mirrors standard audit practice of pairing a targeted risk assessment with a general controls assessment so that neither a false sense of security from one narrow “yes” heavy checklist, nor a generic maturity score without threat context, drives the final conclusions on its own.

3.0 Assessment Process

3.1 Scope and Objectives

Scope: National Oilwell Varco

Objective: identify gaps in ransomware-specific readiness (RRA) and in general cybersecurity capability (CIS), and translate both into a prioritized, evidence-based improvement plan.

As with any CSET self-assessment, the results below are based on my answers as employee. The Observations Tear-Out Sheets generated for both modules contained no recorded observations or

attached evidence, meaning the findings have not yet been independently corroborated through document review or technical verification this is carried forward as an audit caveat in Section 4.

3.2 Ransomware Readiness Assessment (RRA) – Methodology and Results

The RRA organizes 10 goals into three progressive tiers which are Basic, Intermediate, and Advanced. Each practice answered Yes or No. A tier is considered achieved once all its practices are answered Yes.

RRA Goal	Result	Tier Coverage
Robust Data Backup (DB)	100% Yes	All tiers
Web Browser Management and DNS Filtering (BM)	100% Yes	All tiers
Phishing Prevention and Awareness (PP)	100% Yes	All tiers
Network Perimeter Monitoring (NM)	100% Yes	All tiers
Asset Management (AM)	100% Yes	All tiers
Patch and Update Management (PM)	100% Yes	All tiers
User and Access Management (UM)	100% Yes	All tiers
Application Integrity and Allowlist (AI)	100% Yes	All tiers
Incident Response (IR)	100% Yes	All tiers
Risk Management (RM)	100% Yes	All tiers

Overall performance: 100% Yes, Intermediate (17/17), and Advanced (13/13) tiers. The accompanying Deficiency (Gap) Report confirms there are no deficiencies to display. Every practice answered Yes, so no ransomware-specific control gaps were flagged by the tool.

3.3 Cyber Infrastructure Survey (CIS) – Methodology and Results

The CIS scores 28 individual sections that grouped into 9 categories on a 0–100 scale based on the participant's answers to each section's question set. No baseline comparison survey was selected for this run, so scores are read against general good-practice expectations. Broadly, scores at or above 75–80 indicate a well-managed area, while scores below 50 indicate a material gap warranting attention. Section scores are approximate, visually read from the CSET Section Scoring bar charts.

Category	Section	Estimated Score
Cybersecurity Management	1. Cybersecurity Leadership	68
Cybersecurity Architecture	2. Inventory	90
Cybersecurity Architecture	3.System Architecture	68
Cybersecurity Architecture	4.Security Architecture	73
Cybersecurity Architecture	5.Change Management	90
Cybersecurity Architecture	6.Lifecycle Tracking	75
Cybersecurity Architecture	7.Assessment and Evaluations	65
Cybersecurity Architecture	8.Cybersecurity Plan	~88
Cybersecurity Architecture	9.Cybersecurity Exercises	~80
Information Sharing	10.External Information Sharing	~65
Information Sharing	11.Internal Information Sharing	~75
Cybersecurity Forces	12. Personnel	~80
Cybersecurity Forces	13.Cybersecurity Training	~50
Cybersecurity Controls	14.Authentication and Authorization Controls	~80
Access Controls	15. Access Paths	~92
Access Controls	16.Remote Access Controls	~92
Cybersecurity Measures	17.Malicious Code Controls	~40
Cybersecurity Measures	18.Monitoring and Scanning	~92
Cybersecurity Measures	19.Security and Event Log	~25
Cybersecurity Measures	20.Information Protection	~85
Cybersecurity Measures	21. User Training	~85
Cybersecurity Measures	22.Defense Sophistication and Compensating Controls	~92
Incident Response	23. Incident Response Measures	~78
Incident Response	24. Alternate Site and Disaster Recovery	~75
Dependencies	25. Dependencies – Data at Rest	~32
Dependencies	26. Dependencies – Data in Motion	~65
Dependencies	27. Dependencies – Data in Process	~68
Dependencies	28. Dependencies – End Point Systems	~50

4.0 Report Generation – Findings, Benchmarking, and Recommendations

4.1 Identified Risks and Vulnerabilities

The RRA result is uniformly strong, so it surfaces no ransomware-specific gap on its own. The CIS survey provides a broader view, where the real variance and priority risks emerge. The lowest scoring sections are:

- Security and Event Log – the weakest area overall and logging or event-monitoring capability undermines detection and forensic reconstruction of any incident, ransomware or otherwise.
- Dependencies – Data at Rest - weak understanding or protection of dependencies for stored data, which affects both confidentiality and recovery planning.
- Malicious Code Controls – anti-malware or endpoint protection capability is below expectation, directly relevant to ransomware delivery and execution.
- Cybersecurity Training and Dependencies (End Point Systems) – workforce readiness and endpoint-dependency mapping are only partially mature.

These four to five areas are the organisation's real exposure and notwithstanding the perfect RRA score, because weak logging and weak malicious-code controls are precisely the capabilities that determine whether a ransomware precursor is detected before encryption occurs.

4.2 Benchmarking Against Industry Standards

- RRA: achieving 100% Yes across Basic, Intermediate, and Advanced tiers exceeds CISA's own expectation that most organisations progress tier-by-tier over time. CISA guidance treats full Basic-tier completion as the minimum bar and Advanced-tier completion as an aspirational target so a full sweep across all three tiers is an unusually strong result and per the audit caveat below, warrants independent verification before being relied upon for assurance purposes.
- CIS: sections scoring in the 85–92 range of Inventory, Change Management, Access Paths, Remote Access Controls, Monitoring and Scanning, Defense Sophistication, Information Protection, User Training are consistent with a mature, well-resourced enterprise security programme, which is plausible for an organisation the size of National Oilwell Varco.
- Sections below 50, which are Security and Event Log, Dependencies fall well short of what NIST CSF's Detect and Protect functions and common industrial or IT sector guidance, expect for logging and data-dependency management, which is particularly relevant given the organisation's likely OT/ICS footprint as an oilfield equipment manufacturer.

4.3 Recommended Mitigation / Improvement Strategies

Priority	Recommendation	Target Area
High	Expand centralised security event logging and alerting coverage across IT and, where applicable, OT assets.	Security and Event Log
High	Upgrade malicious-code/endpoint protection to include behavioural detection, not signature-only, and verify coverage across all endpoints.	Malicious Code Controls
Medium	Complete a dependency mapping exercise for data at rest to close visibility gaps used in recovery planning.	Dependencies (Data at Rest)
Medium	Refresh and broaden cybersecurity training cadence or content for staff, and map endpoint dependencies to reduce blind spots.	Cybersecurity Training or End Point Systems
Medium	Independently verify the RRA's 100% self-reported result (document review, control testing, or a facilitated CSET session with evidence attached) before relying on it for external assurance purposes.	RRA – Assurance Quality

5. Conclusion

National Oilwell Varco's self-reported ransomware specific practices (RRA) are fully in place but the broader Cyber Infrastructure Survey shows that supporting capabilities such as security event logging, malicious-code defence, data-at-rest dependency visibility, and training are materially weaker and are exactly the capabilities that would determine whether a real ransomware attempt is caught early or allowed to progress. The RRA answers “are the named ransomware controls in place,” while the CIS answers “is the underlying security programme mature enough to make those controls reliable,” and the second question reveals the organisation's critical priorities for investment. Without addressing the identified gaps in logging, malicious code controls, and dependency visibility, the organisation's otherwise robust ransomware controls may fail to prevent or contain an actual attack.

